

Internal Brain (Aspire / FinTech track) — Architecture & Build Plan

Context

Aspire's challenge: a permission-aware AI knowledge system over Confluence, Jira, Slack and Google Drive. It needs RBAC enforced end to end, a tamper-evident audit trail, data freshness within minutes to an hour, and no leakage, including through the LLM. Deadline is **16 Oct 2026 (~15 days)**. Hard requirement: build on **CodeBuddy or WorkBuddy**, with proof (3+ chat screenshots or logs). Scoring is 10 criteria x 10 points. The Responsible AI & Ethics criterion lines up directly with this brief.

Thesis: *The model proposes, a deterministic policy plane disposes.* The LLM never sees unauthorized content, holds no credentials and has no write tools. Every claim in an answer is traceable to a chunk that was authorized at read time, and every decision is written to a hash-chained audit log.

Inspiration, and what we do differently

- **Onyx** (MIT core): hybrid search (vector + BM25), 40+ connectors, ACLs inherited from the source and filtered at query time. Its permission sync for Confluence, Jira, Slack and Drive is **Enterprise Edition only**, so we can't fork it. We also don't want to, since the project must be original and judged on technical execution. We borrow the ideas: ACL tokens stored on every chunk, and filtering before retrieval.
- **Atlassian Rovo hybrid LLM:**
 - Small models handle query rewriting and relevance checks; the strongest model handles generation.
 - Two-stage rewriting (semantic query plus keyword variants).
 - Parallel multi-source search.
 - LLM-judge evals.
 - The article says nothing about permissions, which is our differentiation.
- **Gaps in existing systems that we close:**
 - Prefilter-only ACLs go stale after a revocation.
 - Cross-links between platforms can leak the existence of documents.
 - Nobody verifies the answer for leakage after generation.
 - Audit logs are rarely tamper-evident or queryable by an agent.

Architecture (zones and trust boundaries)

- 1 **Edge (untrusted):** web chat UI, admin/audit console, and an **MCP server** that exposes the Brain to CodeBuddy and WorkBuddy.
- 2 **Gateway:** authentication through a mock OIDC IdP. It resolves the user's identity to per-platform identities (email, Slack ID, Jira accountId) and group memberships.
- 3 **Policy plane (trusted, no LLM):**
 - Policy decision point (PDP) with one ACL evaluator per source, **keeping native semantics**:
 - Confluence: space permissions plus inherited page restrictions.
 - Jira: project roles plus issue security levels.
 - Slack: channel membership, private channels and DMs.
 - Drive: inherited folder sharing, file sharing, external links.
 - Connectors with a `check_access(user, doc)` call and a `version(doc)` call.
 - Audit service (hash-chained, signed checkpoints).
- 4 **Data plane:** Postgres with pgvector, full-text search and a GIN index on `acl_tokens[]`. Source-native ACL evidence is stored next to normalized access tokens.

- 5 **LLM plane (untrusted):** LangGraph agents that see only authorized, sanitized, delimited context. They get no connector credentials and no tools that write.

Query path (LangGraph state machine; policy nodes are plain code)

- 1 **Identify the asker and resolve groups.**
- 2 **Rewrite and route (small model):** intent, which platforms are relevant, semantic query plus keyword variants.
- 3 **ACL-prefiltered hybrid retrieval:** per-platform fan-out with BM25 and vectors, filtered on the asker's tokens. Merge with reciprocal-rank fusion, then rerank.
- 4 **Just-in-time verification:**
 - For each of the top-k candidates, call the PDP and connector `check_access`, with a short-TTL cache.
 - Compare the source `version` against the indexed version. If stale, re-fetch inline (read-through).
 - Log an allow or deny decision per document.
 - This is what handles live revocation and freshness; the minutes-to-an-hour freshness window then only affects what is discoverable, not what is served.
- 5 **Link-graph expansion:** follow Jira ↔ Slack ↔ Confluence ↔ Drive links, but a hop is taken only if the target also passes the PDP (no existence leaks through links).
- 6 **Sanitize and spotlight:** wrap chunks in delimiters, strip instruction-like text, and flag it (defense against prompt injection through retrieved content).
- 7 **Generate:** structured output of claims, each with source chunk IDs. Strongest model.
- 8 **Verify:**
 - A second model checks each claim against its cited chunk.
 - A leakage scanner compares the answer with the user's **denied** candidate set. It runs server-side and the result is never shown to the user.
 - If support is missing, abstain or redact.
- 9 **Uniform refusal:** denied and nonexistent content get the same answer shape and timing, with no counts and no titles.
- 10 **Audit write:** the log entry holds who, query, retrieved IDs, allow/deny per document, answer hash, model versions and a timestamp, chained by hash to the previous entry.

Freshness

Event-driven ingestion (webhooks, Slack events, Drive push notifications) plus an incremental poll as fallback. Each citation shows an "as of" timestamp. A dashboard shows freshness lag p50/p95.

Audit and compliance

- **Hash chain with signed checkpoints.** A `/verify` endpoint reports any broken link, so tampering or deletion is detectable.
- **Natural-language audit queries**, answered by a read-only audit agent that is itself under RBAC. Example: "Show me everything jdoe accessed in payment-gateway in 30 days."
- Denied document IDs are stored hashed, so auditors can see attempts without the log becoming a leak.

Tencent product usage

Product	Role	Required?
CodeBuddy Code (CLI, SDK, headless, skills, subagents, MCP)	Primary build tool: scaffold, tests, red-team generation, seed data. Keep screenshots and logs as proof .	Mandatory (CodeBuddy or WorkBuddy)
WorkBuddy	Runs as a real client of the Internal Brain MCP server . Also runs a scheduled weekly compliance report from the audit API.	Mandatory option; we use both

Product	Role	Required?
Tencent Cloud Lighthouse/CVM (Singapore)	Hosts the live demo URL (bonus points).	Optional
TRTC ASR/TTS	Voice questions and spoken answers, an accessibility win.	Optional stretch
ADP	Pluggable generation/verifier backend (DeepSeek via the Chat API and AppKey). Not our retrieval store.	Optional
Hunyuan embeddings	Primary embedder (1024-d, rate-limited, so batch). Local bge-m3 as fallback.	Optional

Why ADP is not the core: its knowledge base is a general RAG store with platform/space/application/KB-level permissions. It doesn't ingest per-user ACLs from Confluence, Jira, Slack or Drive. Uploading documents into it would bypass our permission model. We call it only with already-authorized context, so it can only ever see what the asker may see.

Why LangGraph over ADP workflows or plain LangChain:

- It gives explicit state and typed nodes.
- It makes deterministic policy gates easy to separate from LLM nodes.
- Its traces make a good demo.
- The model gateway swaps backends (ADP/DeepSeek, Hunyuan, others) behind one interface.

Innovation hooks (calibrated: individual pieces exist somewhere; our edge is the combination plus measured proof)

Already exists in 2026, so we don't claim it as new: query-time ACL filtering (Glean, Onyx EE, Microsoft Copilot), hash-chained agent audit libraries (Waxseal, AuditWeave, inference-receipts, an IETF draft), and discussion of MCP identity propagation.

What we add:

- 1 **Answer-level ACL labels (information-flow control).** Every derived artifact (answer, summary, cache entry, agent memory) carries the *intersection* of its sources' ACLs. A cached or shared answer can only be served to someone who qualifies for all of its sources. I found no product doing this in the material I checked.
- 2 **Closing the revocation window.** Mirrored-ACL systems have a gap between "access revoked" and "index notices" during which they serve stale-permitted content. We re-verify at read time and **measure and publish revocation-to-enforcement time**.
- 3 **Link-edge authorization.** Cross-platform links (Jira ↔ Slack ↔ Confluence ↔ Drive) are followed only if the target is also authorized. This stops existence leaks through links.
- 4 **Post-generation leakage scan against the denied set,** run server-side. Canary strings planted in restricted documents make it testable.
- 5 **Replayable authorization audit.** Each log entry stores the ACL snapshot hash and policy version, not just "allowed". An auditor can re-evaluate whether the decision was correct at that time. The chain is hash-linked, with a */verify* endpoint.
- 6 **Identity-propagating MCP server.** CodeBuddy and WorkBuddy act as real clients of the Brain with per-user identity and no shared service credential.
- 7 **Built-in red-team harness with a public scoreboard:** prompt injection planted in documents, existence side-channel probes, canary strings, revocation races. Metrics: leaks 0/N, freshness p95, citation precision.

Additional innovation candidates (brainstorm; I can't prove "nothing like it exists", only that I found none in the products and papers I checked)

Headline (build these):

- **A. Noninterference CI ("Leak-CI").** Security property: *a user's answer must not change if documents they can't see are added, removed or edited.* We test it automatically with metamorphic tests: insert or delete hidden documents, re-ask as the same user, and compare answers, refusal wording and latency bands. It runs as a CI gate with a leak-rate scoreboard. Recent RAG-leakage work (LeakDojo and others) measures attacks; I found nothing productizing this as a release gate.
- **B. Answer recall and stale-answer alerts.** Because the audit log records which sources backed each answer, when a source changes (or access is revoked) we flag answers that relied on it and notify the people who received them. Example: "The runbook answer you got at 2:05 was superseded at 2:30: new failover step." This pairs with answer-level ACL labels to make cached answers safe. Directly addresses the on-call scenario in the brief.
- **C. Bi-temporal permissions with time-travel and proof paths.** Store ACL snapshots with validity intervals, so an auditor can ask "what could jdoe see on 12 Sept?" and every allow decision carries a minimal **proof path** ("via group payments-eng → space PAY"). The same path powers the user-facing "why can I see this?" explanation.

Stretch (only if the core is done):

- **D. Sensitivity-aware model routing.** Restricted-class content is only ever sent to an in-region model (Tencent Cloud Singapore: Hunyuan/DeepSeek via ADP); other queries may use stronger external models. Extends Atlassian's cost-driven hybrid-LLM idea to a *confidentiality*-driven one. Speaks to Singapore fintech data-residency concerns.
- **E. Mosaic/aggregation guard (experimental).** Individually authorized answers can combine to reveal something sensitive. Track per-session disclosure by sensitivity class, then warn, throttle or flag in the audit. Flag it as research-grade.
- **F. Honeytoken documents** in restricted spaces: any retrieval attempt raises an insider-threat alert in the audit console.
- **G. User-visible access receipts:** each user can see what the Brain accessed on their behalf (transparency for Responsible AI).

Data and environment: real connectors from day 1 (decided), plus simulators for scale

All four connectors are built against the **real APIs** in tenants we create ourselves ("Company A" seed data: payment outage, DB migration, Q3 breach report in a restricted space). A **simulator** (FastAPI, same API shapes and permission semantics) runs the *same connector contract tests*. Real tenants prove fidelity. The simulator provides scale (12k pages, 200+ channels) and the adversarial and revocation-race tests that are impractical to run on real tenants.

Feasibility findings (from searches; verify before relying):

- **Slack:** the 2025 rate-limit cut (1 request/min, 15 objects for `conversations.history/replies`) hits *commercially distributed non-Marketplace* apps. A custom internal app in our own workspace should be exempt. Use the Events API for real-time messages.
- **Google Drive:** `changes.watch` push notifications and the permissions API work. Domain-wide delegation needs paid Workspace, so use per-user OAuth with several test Google accounts instead.
- **Atlassian (biggest risk):** the Free plan reportedly has **no space/page permissions and no project/issue permissions**, which is the heart of this challenge. Options: (a) a paid-plan trial for a time-boxed window to capture real permission behavior and record the demo, (b) ask Tencent/Aspire for a sandbox, (c) run Atlassian permissions through the simulator and say so honestly. Plan: build the connector now, test permissions on the simulator, and use a trial window for the real recording. Verify trial length and which plan includes issue-level security.

UX and demo story

- **Split-screen persona demo:** Backend Engineer, Contractor and Security Lead ask the same question and get three different, correct answers.
- **Live revocation:** remove access in a mock Slack channel and re-ask, and the content disappears.
- **Live freshness:** edit a Confluence page and the new failover step appears.
- **Admin console:** permission-graph viewer, audit explorer, freshness dashboard.
- **Accessibility:** keyboard navigation, ARIA, high contrast, optional voice with TRTC.

Judging coverage

Criterion	Where we score
Impact & Relevance	The 30%-search-time problem plus the "can it leak everything" fear
Human-Centered Design	Explainable "why you can see this", persona UI
AI Interaction	Routing, rewrite, verifier, MCP use
Technical Execution	PDP, JIT checks, hash chain, evals
Feasibility	Production path (OpenFGA/SpiceDB, real connectors)
Demo & Storytelling	Split-screen demos of all 5 scenarios
Innovation	The hooks above
UX & Accessibility	Voice, keyboard, admin console
Responsible AI & Ethics	Zero-leak, abstention, red-team scoreboard
Overall	Polish, live URL, video

Team split (3 people)

- **Person 1, Sources and freshness:** the four real connectors (Slack, Drive, Confluence, Jira), webhooks and event ingestion, the simulator, the ACL evaluators.
- **Person 2, Brain and policy:** PDP, retrieval, LangGraph query path, verifier and leakage scan, audit chain, MCP server, ADP/model gateway.
- **Person 3, Experience and proof:** UI and admin console, persona demo, red-team and Leak-CI, evals, deployment, diagrams, demo video, submission artifacts (including CodeBuddy/WorkBuddy proof).

Shared contract on day 1: the connector interface (`list_changes`, `fetch`, `check_access`, `version`) and the audit-event schema.

Schedule (~15 days, 3 people in parallel)

- **Days 1-2:** repo, mock Company A (4 platforms with ACLs), seed data, Postgres schema, CodeBuddy workflow set up (screenshots from day 1).
- **Days 3-5:** connectors and ingestion, ACL tokens, hybrid retrieval, PDP.
- **Days 6-8:** LangGraph query path, JIT checks, freshness, generation, verifier, leakage scan.
- **Days 9-10:** audit chain, audit agent, MCP server, WorkBuddy client and scheduled report.
- **Days 11-12:** UI and admin console, red-team harness, evals.
- **Days 13-14:** deploy to Singapore, polish, architecture and trust diagram, demo video, README.
- **Day 15 (buffer):** submit by 16 Oct.
- **Stretch:** TRTC voice, real connector.

Risks to verify early

- Hunyuan LLM/embedding access from outside China regions (search shows regions ap-guangzhou and ap-beijing), plus the 5 requests/s embedding limit. Fallback: bge-m3 locally.
- ADP free quota, latency and whether the Chat API takes per-request context. Fallback: other models behind the gateway.
- WorkBuddy MCP client support (confirm in practice).
- Mocks vs real connectors (ask Aspire).
- Judging criteria specific to the track.
- Keep AppKeys and secret keys out of the proof screenshots.

Verification (end to end)

- Golden test set with expected allowed and denied sets per persona. Pass bar: **0 leaks**.
- Red-team suite passes.
- Chain `/verify` fails when a log row is edited or deleted.
- Revocation takes effect on the next query.
- Edit propagates within the SLA.
- Run all 5 scenarios live through the UI and through WorkBuddy via MCP.